tekras

CYBERSECURITY CONSULTANCY

Pentest report

Logística Demo, S.A.

PROJECT	DATE	VERSION
TKR-DEMO-001	October 23, 2026	1.0

Sample document. The company, people, systems and findings are fictional.

CONTENTS

Contents

DOCUMENT INFORMATION

Confidentiality and document control 3

EXECUTIVE REPORT

Executive summary 4

Prioritized remediation plan 5

SCOPE AND METHODOLOGY

Scope 6

Methodology and risk rating 7

TECHNICAL REPORT

Attack paths 8

Findings summary 9

- INT-01 · A certificate template allows impersonating an administrator 10
- WEB-01 · SQL injection in the customer portal's shipment search 11
- INT-03 · Same local administrator password on 38 servers 12
- INT-02 · Privileged service account with a weak password 13
- PRV-01 · Excessive permissions on a Windows service 14
- PRV-02 · Overly broad sudo rules on Linux servers 15
- EXT-01 · Remote access without a second authentication factor 16
- WEB-02 · A customer can view other customers' invoices and shipments 17
- SOC-01 · Credentials submitted during the controlled phishing campaign 18
- INT-04 · Legacy name resolution protocols enabled 19
- OSI-01 · Corporate information exposed in open sources 20
- EXT-02 · Email domain without a DMARC reject policy 21
- EXT-03 · Obsolete encryption protocols on the mail server 22

CONCLUSION

Conclusion 23

DOCUMENT INFORMATION

Confidentiality and document control

About this sample. The actual report includes real screenshots of the tools used and of the vulnerabilities found, exactly as they appear in Linux. In this sample, those screenshots have been replaced with illustrative images.

Confidentiality

This document is the property of Logística Demo, S.A. and contains confidential information about its security. Distributing it, in whole or in part, requires authorization from Logística Demo, S.A. and Tekras. The handling of this information is governed by the non-disclosure agreement signed by both parties before the project began.

Limitations

This report reflects the state of the systems during the testing window. A time-limited assessment does not guarantee that all existing vulnerabilities are detected, and later changes may alter the risk level.

Information handling

Collected information was protected during the project and will be deleted when it closes.

Contacts

ORGANIZATION	ROLE	EMAIL
Logística Demo, S.A.	IT Management	ti@logisticademo.example
Tekras	Pentesting team	ventas@tekras.com

Version control

VERSION	DATE	DESCRIPTION
0.9	October 21, 2026	Draft for internal review
1.0	October 23, 2026	Final report

EXECUTIVE REPORT

Executive summary

Tekras assessed the internal and external security of Logística Demo, S.A. from October 5 to 16, 2026, using controlled ethical hacking techniques.

OVERALL RISK LEVEL

Critical

Two paths that compromise critical assets were demonstrated: one to customer data and another to full domain control.

Findings by risk level



13 findings in total.

Business impact

Customer data is exposed to the internet. A flaw in the portal would allow anyone to access shipment and billing information, without needing an account.

A single deceptive email can end in control of the entire network. Starting from a password submitted during the phishing campaign, the Tekras team gained control of the company domain.

Strengths and weaknesses

Observed strengths

- Workstation protection detected part of the testing activity.
- Nine employees reported the campaign email.
- Backups are stored separately from the main network.

Main weaknesses

- Remote access relies on a password alone.
- Privileged accounts are not sufficiently protected.
- The customer portal had not been assessed since launch.

EXECUTIVE REPORT

Prioritized remediation plan

The three immediate actions close both demonstrated attack paths.

WHEN	WHAT TO DO	FINDINGS	EFFORT
Immediate 0 to 15 days	Fix the portal's SQL injection and the certificate template. Require a second factor for remote access.	WEB-01, INT-01, EXT-01	Medium
Short term 15 to 60 days	Assign unique local passwords, protect service accounts and fix the portal's access control.	INT-03, INT-02, WEB-02	Medium
Medium term 60 to 120 days	Adjust Windows and Linux permissions and disable legacy protocols. Strengthen staff training.	PRV-01, PRV-02, INT-04, SOC-01	Low
Maintenance Next cycle	Publish a DMARC reject policy, update mail encryption and define what information gets published.	EXT-02, EXT-03, OSI-01	Low

Timelines and effort are estimates and should be adjusted to the operations and resources of Logística Demo, S.A.

SCOPE AND METHODOLOGY

Scope

Testing took place from October 5 to 16, 2026, in the windows agreed with Logística Demo, S.A. The scope and authorization letter were signed before testing began.

AREA TESTED	ITEMS INCLUDED
OSINT	Public information about the company and its staff
External pentesting	203.0.113.0/24, vpn. and correo.logisticademo.example
Web applications	portal.logisticademo.example
Internal network & identities	10.20.0.0/16 and domain corp.logisticademo.example
Privilege escalation	Windows and Linux systems within scope
Social engineering	Controlled phishing campaign for 120 employees

Out of scope

- Denial-of-service testing.
- Third-party systems and cloud providers.
- Social engineering by phone or in person.

SCOPE AND METHODOLOGY

Methodology and risk rating

Testing was based on OWASP WSTG, PTES, NIST SP 800-115 and MITRE ATT&CK, in the following phases:

1. **Scope & rules.** What would be tested, when and under which conditions was defined with the client.
2. **Reconnaissance & OSINT.** Information was gathered and the attack surface was mapped.
3. **Controlled exploitation.** The vulnerabilities found were safely exploited to gain an initial foothold and measure their real impact.
4. **Escalation & lateral movement.** From that foothold, the team assessed how far an attacker could go: privileges, other machines and identity services.
5. **Final report.** Every finding was documented and ranked by risk level.

Risk levels

Each finding is rated by its likelihood and its business impact. Where applicable, the CVSS 3.1 score is used as a reference.

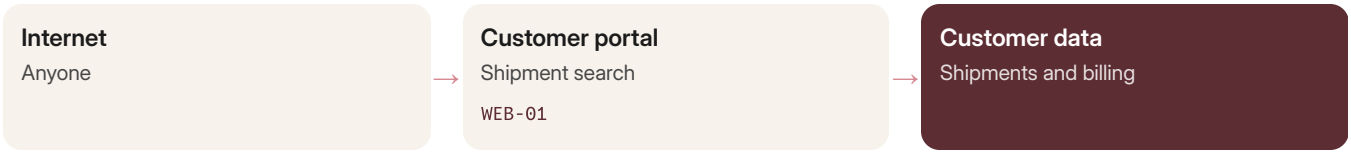
LEVEL	CVSS 3.1	WHAT IT MEANS
Critical	9.0 – 10.0	Compromises essential systems or data with little effort. Requires immediate action.
High	7.0 – 8.9	Allows elevated privileges or access to sensitive data under certain conditions. Fix as a priority.
Medium	4.0 – 6.9	Facilitates an attack or requires additional steps to cause harm. Fix after high risks.
Low	0.1 – 3.9	Limited effect, but reduces the attack surface. Fix in the next maintenance window.

TECHNICAL REPORT

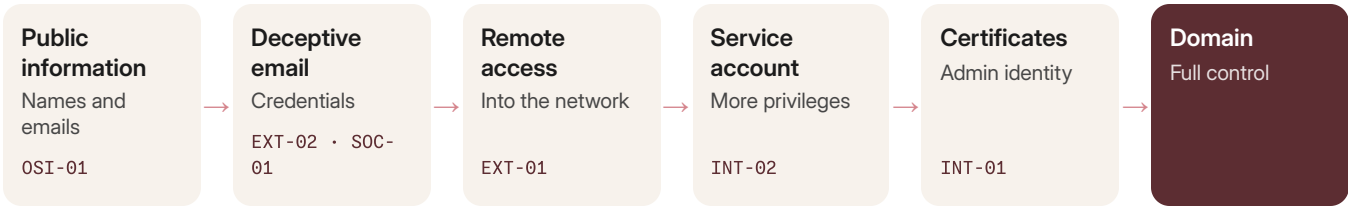
Attack paths

Several findings become more serious when chained together. Two paths were demonstrated during the assessment.

Path 1. From the internet to customer data



Path 2. From an email to domain control



Other findings. PRV-01, PRV-02, INT-03, INT-04 and WEB-02 are not part of these paths, but they offer alternate routes or increase the potential damage.

TECHNICAL REPORT

Findings summary

ID	FINDING	RISK	MAIN RECOMMENDATION
INT-01	A certificate template allows impersonating an administrator	Critical	Restrict the template and require approval.
WEB-01	SQL injection in the customer portal's shipment search	Critical	Use parameterized queries across the portal.
INT-03	Same local administrator password on 38 servers	High	Use a unique local password per machine.
INT-02	Privileged service account with a weak password	High	Migrate to managed service accounts.
PRV-01	Excessive permissions on a Windows service	High	Fix the permissions in the standard image.
PRV-02	Overly broad sudo rules on Linux servers	High	Limit sudo to the required tasks.
EXT-01	Remote access without a second authentication factor	High	Require a second factor for remote access.
WEB-02	A customer can view other customers' invoices and shipments	High	Validate record ownership on the server.
SOC-01	Credentials submitted during the controlled phishing campaign	High	Strengthen training and email reporting.
INT-04	Legacy name resolution protocols enabled	Medium	Disable LLMNR and NBT-NS by policy.
OSI-01	Corporate information exposed in open sources	Medium	Define what gets published and review it regularly.
EXT-02	Email domain without a DMARC reject policy	Medium	Publish DMARC and move toward reject.
EXT-03	Obsolete encryption protocols on the mail server	Low	Disable TLS 1.0 and 1.1.

INT-01 · INTERNAL NETWORK & IDENTITIES

A certificate template allows impersonating an administrator

RISK	CVSS 3.1	AFFECTED ASSET
Critical	9.9	Certificate service for the corp.logisticademo.example domain

AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

What we found

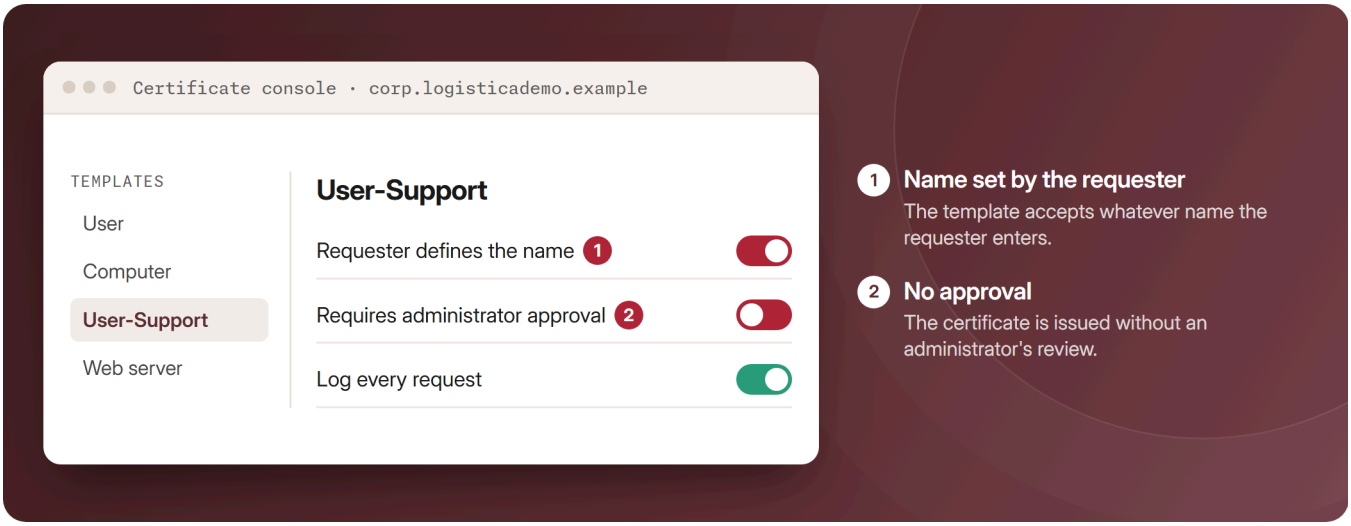
A template in the certificate service lets the requester state who the certificate is issued to. An account allowed to use that template can obtain a valid certificate in another identity's name, including an administrator account.

Business impact

This is the last step of the path that led to full domain control. Whoever controls the domain can access the company's servers, email and data.

Remediation recommendations

- Remove the template option that lets the requester define the name.
- Limit who can request certificates and require administrator approval.
- Regularly review all published templates and their permissions.



Evidence. Configuration of the User-Support certificate template. Illustrative image: the actual report includes the real tool screenshot.

Steps to reproduce

1. **Template inventory**
   An authorized account was used to review the templates published in the domain's certificate service.
2. **Configuration review**
   A template was identified that lets the requester define the name and requires no approval.
3. **Permission check**
   The team confirmed which groups can request it and how they relate to the account in finding INT-02.
4. **Confirmation and cleanup**
   The risk was validated with the client's contact and test items were removed.

General steps. Technical detail is omitted from this public sample.

REFERENCES MITRE ATT&CK T1649 · NIST SP 800-53 AC-6

WEB-01 · WEB APPLICATIONS

SQL injection in the customer portal's shipment search

RISK	CVSS 3.1	AFFECTED ASSET
Critical	9.8	portal.logisticademo.example

AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

What we found

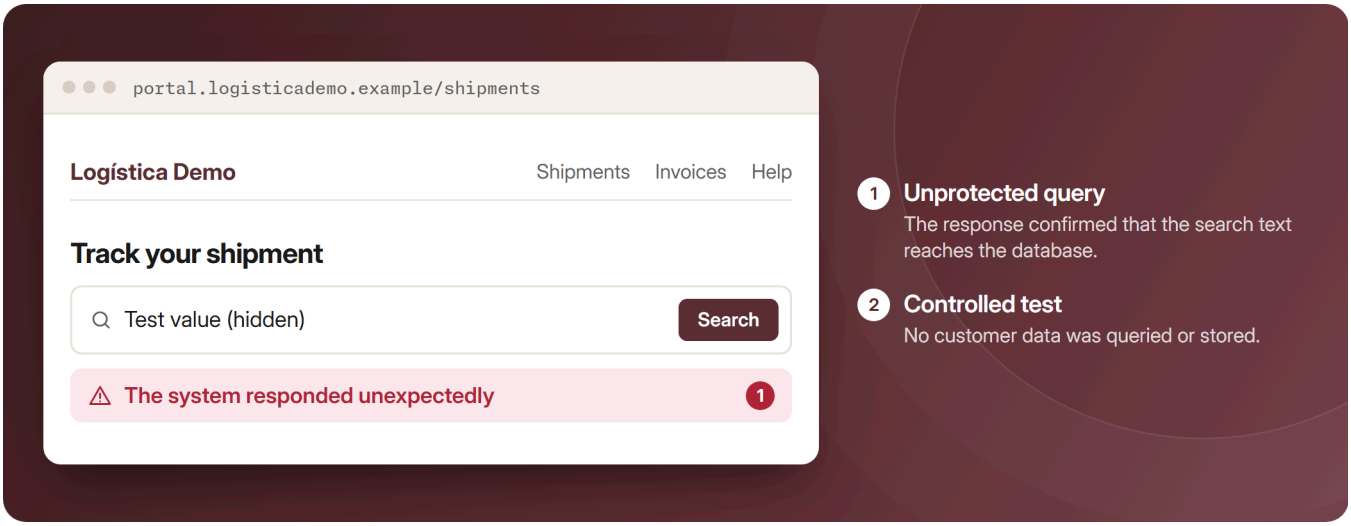
The public shipment search does not separate the text a user types from the instructions sent to the database. It was confirmed, without logging in, that those queries could be altered. Verification was limited to demonstrating access, and no customer data was extracted.

Business impact

Anyone on the internet could read or modify customer, shipment and billing data, leading to data exposure and loss of trust.

Remediation recommendations

- Use parameterized queries in every portal function.
- Connect the portal to the database with a least-privilege account.
- Review historical logs to rule out prior use of this weakness.



Evidence. Verification of the shipment search using a test value. Illustrative image: the actual report includes the real tool screenshot.

Steps to reproduce

1. **Entry point identification**
   The portal's public functions were reviewed and the shipment search, available without logging in, was selected.
2. **Behavior test**
   During the agreed window, the response to a normal search was compared with that of a test search.
3. **Controlled confirmation**
   The response confirmed that the query is not protected. Testing stopped at that point.
4. **Recording the result**
   Evidence was documented without querying or storing customer data.

General steps. Technical detail is omitted from this public sample.

REFERENCES OWASP WSTG-INPV-05 · CWE-89 · MITRE ATT&CK T1190

INT-03 · INTERNAL NETWORK & IDENTITIES

Same local administrator password on 38 servers

RISK	CVSS 3.1	AFFECTED ASSET
High	8.4	38 Windows servers on network 10.20.0.0/16

AV:A/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

What we found

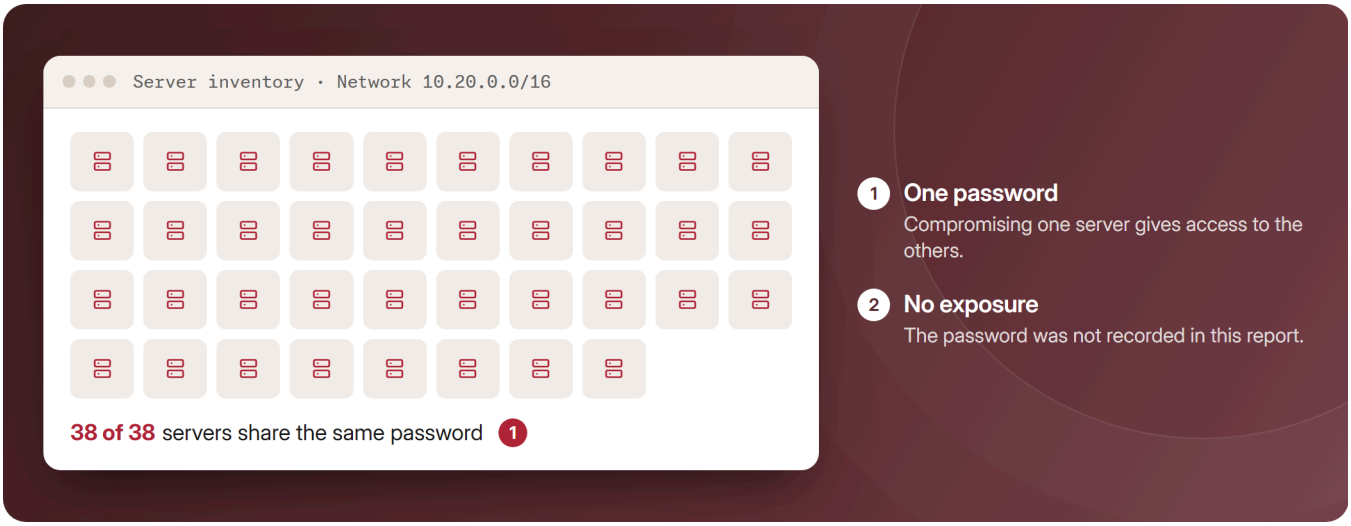
The servers share the same password for their local administrator account. Compromising a single server is enough to gain access to the others.

Business impact

An incident that should stay contained on one server could spread to much of the operation.

Remediation recommendations

- Deploy a solution that assigns and rotates a unique password per machine, such as Windows LAPS.
- Limit remote logon for local accounts.
- Separate the administration network from the user network.



Evidence. Servers sharing the same local administrator password. Illustrative image: the actual report includes the real tool screenshot.

Steps to reproduce

1. **Sample definition**
   The Windows servers included in the review were agreed with the client.
2. **Local account review**
   With authorization, the team verified how the local administrator account is managed on each server.
3. **Server comparison**
   Results were compared, confirming that all 38 servers share the same password.
4. **Recording without exposing secrets**
   The password was not included in this report or in the project notes.

General steps. Technical detail is omitted from this public sample.

REFERENCES MITRE ATT&CK T1078.003 · NIST SP 800-53 IA-5

INT-02 · INTERNAL NETWORK & IDENTITIES

Privileged service account with a weak password

RISK	CVSS 3.1	AFFECTED ASSET
High	8.1	Domain backup service account

AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N

What we found

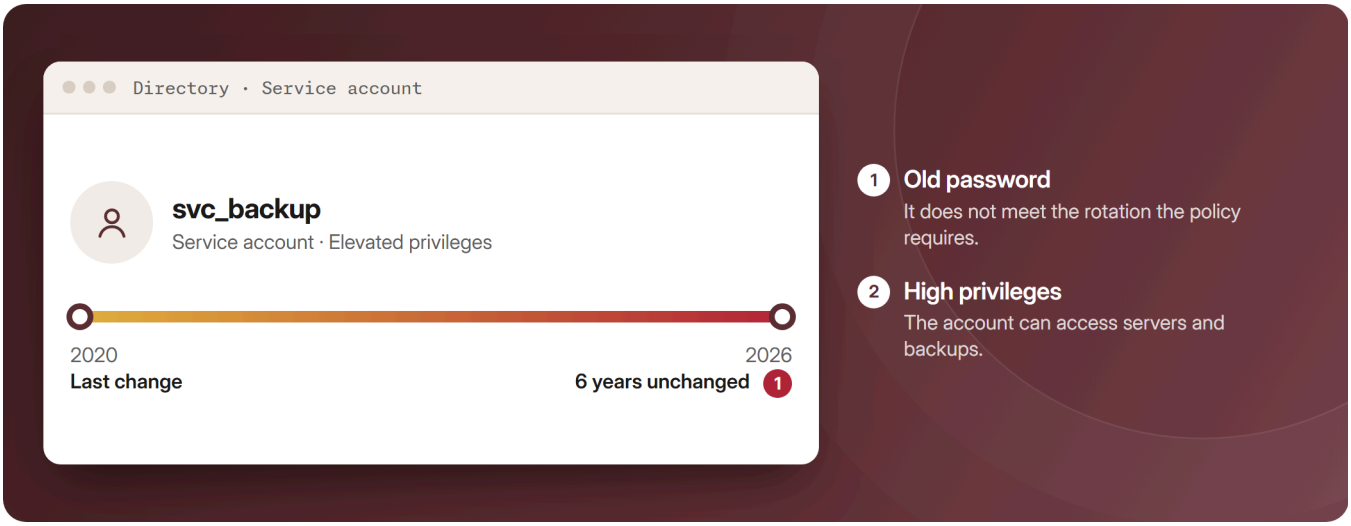
The account that runs backups has elevated privileges and a short password that had not been changed in several years. It was discovered using only a regular domain account.

Business impact

A single compromised user account can become an account with access to servers and backups.

Remediation recommendations

- Migrate to managed service accounts with long passwords and automatic rotation.
- Reduce the account's privileges to what the service needs.
- Review the other service accounts against the same criteria.



Evidence. Age of the backup service account's password. Illustrative image: the actual report includes the real tool screenshot.

Steps to reproduce

1. **Service account review**
   The domain's service accounts and the privileges of each one were identified.
2. **Password age**
   A backup account was found whose password has not changed in six years.
3. **Policy comparison**
   Its configuration was compared with the company's current password policy.
4. **Client validation**
   The team confirmed the account is still in use and documented the extent of its privileges.

General steps. Technical detail is omitted from this public sample.

REFERENCES MITRE ATT&CK T1558.003 · NIST SP 800-63B

PRV-01 · PRIVILEGE ESCALATION

Excessive permissions on a Windows service

RISK	CVSS 3.1	AFFECTED ASSET
High	7.8	Standard Windows workstation image

AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

What we found

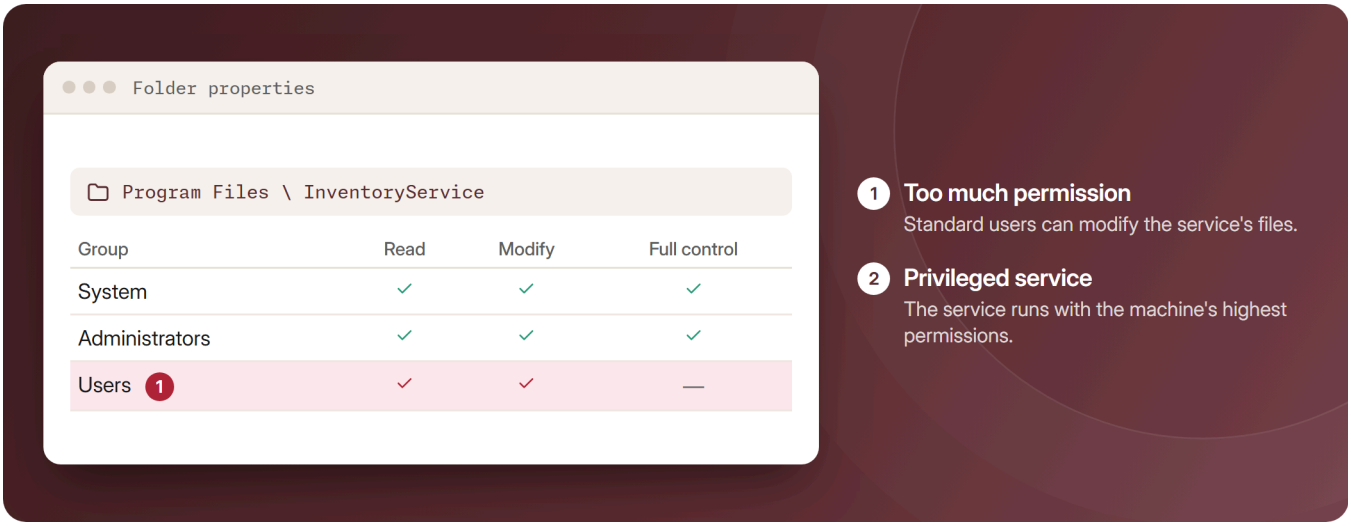
The folder of a service installed in the standard image lets unprivileged users modify its files, even though the service runs with the system's highest permissions.

Business impact

An unprivileged user could gain full control of the machine. Because it is part of the standard image, it affects every workstation built from it.

Remediation recommendations

- Fix the folder permissions and update the standard image.
- Apply the fix to existing machines through policy.
- Include a permissions review when approving new software.



Evidence. Permissions on the InventoryService folder. Illustrative image: the actual report includes the real tool screenshot.

Steps to reproduce

1. **Standard image review**
   A standard test account was used to review the services installed on a corporate workstation.
2. **Permission comparison**
   The account running each service was compared with the permissions on its folder.
3. **Service identification**
   InventoryService runs as System and its folder allows changes by standard users.
4. **Extent of the finding**
   The same permission was confirmed on the other workstations in the sample.

General steps. Technical detail is omitted from this public sample.

REFERENCES MITRE ATT&CK T1574.010 · CWE-732

PRV-02 · PRIVILEGE ESCALATION

Overly broad sudo rules on Linux servers

RISK	CVSS 3.1	AFFECTED ASSET
High	7.8	Linux application servers (3)

AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

What we found

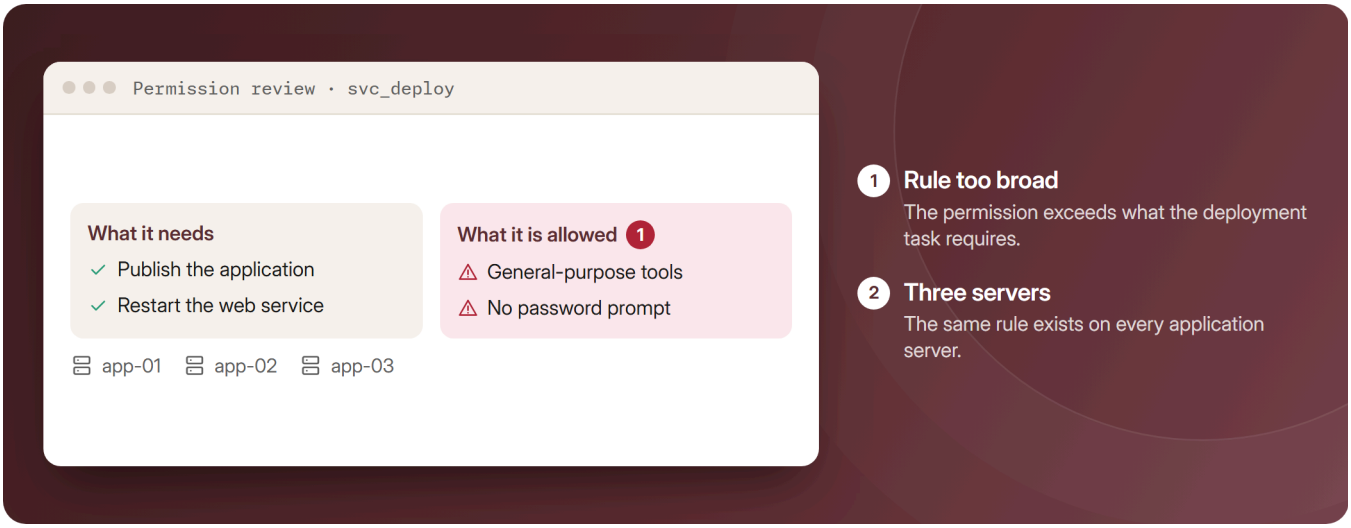
A deployment account can run general-purpose tools as administrator without being asked for a password, beyond what its task requires.

Business impact

Whoever obtains that account would have full control of the servers that run the customer portal.

Remediation recommendations

- Limit sudo rules to specific, required commands.
- Require authentication for administrative tasks.
- Regularly review and log sudo usage.



Evidence. Comparison between what the account needs and what it is allowed to do. Illustrative image: the actual report includes the real tool screenshot.

Steps to reproduce

1. **Task review**
   The tasks the deployment account must perform were identified with the client.
2. **Rule review**
   The sudo rules assigned to that account were reviewed on each server.
3. **Comparison**
   What the rule allows was compared with what the task actually needs.
4. **Documentation**
   Rules that go beyond what is needed were recorded, along with the affected servers.

General steps. Technical detail is omitted from this public sample.

REFERENCES MITRE ATT&CK T1548.003 · CWE-269

EXT-01 · EXTERNAL PENTESTING

Remote access without a second authentication factor

RISK	CVSS 3.1	AFFECTED ASSET
High	7.4	vpn.logisticademo.example

AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N

What we found

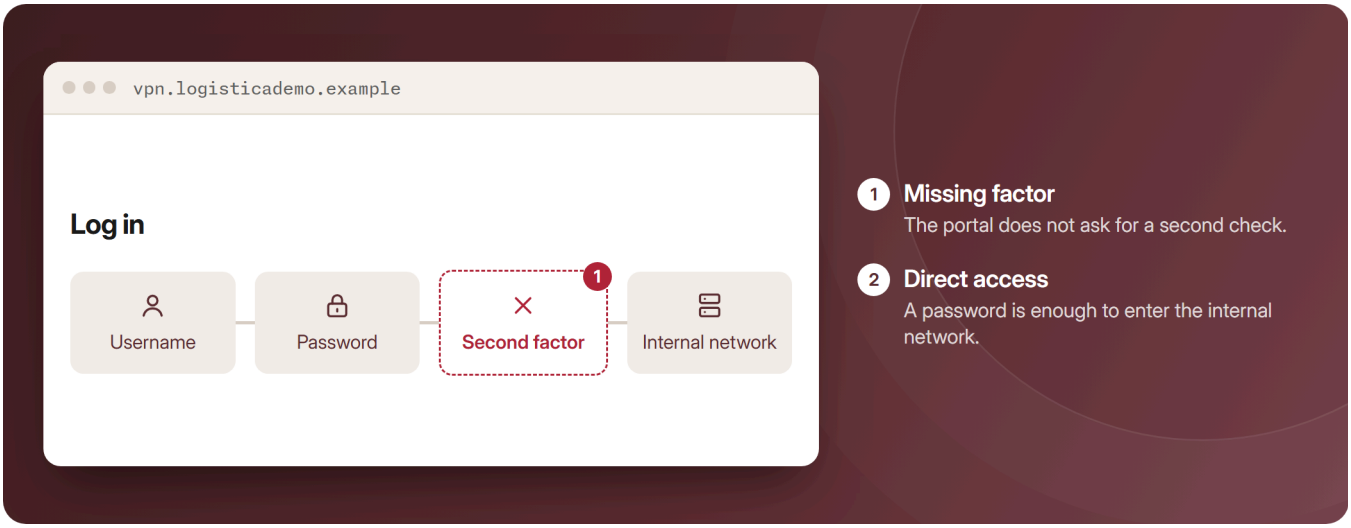
The remote access portal asks only for a username and password. A password obtained by any means is enough to enter the internal network from the internet.

Business impact

It turns a stolen password into direct access to the company network.

Remediation recommendations

- Require a phishing-resistant second factor for all remote access.
- Set up alerts for unusual logins.
- Evaluate an access model based on user identity and device posture.



Evidence. Login process of the remote access portal. Illustrative image: the actual report includes the real tool screenshot.

Steps to reproduce

1. **Portal identification**
   The remote access portal was located among the services exposed to the internet.
2. **Test login**
   An authorized test account was used to log in and observe the process.
3. **Process observation**
   The team confirmed that the portal asks only for a username and password.
4. **Client validation**
   It was verified that the same configuration applies to all users.

General steps. Technical detail is omitted from this public sample.

REFERENCES MITRE ATT&CK T1133 · NIST SP 800-63B

WEB-02 · WEB APPLICATIONS

A customer can view other customers' invoices and shipments

RISK	CVSS 3.1	AFFECTED ASSET
High	7.1	portal.logisticademo.example

AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:L/A:N

What we found

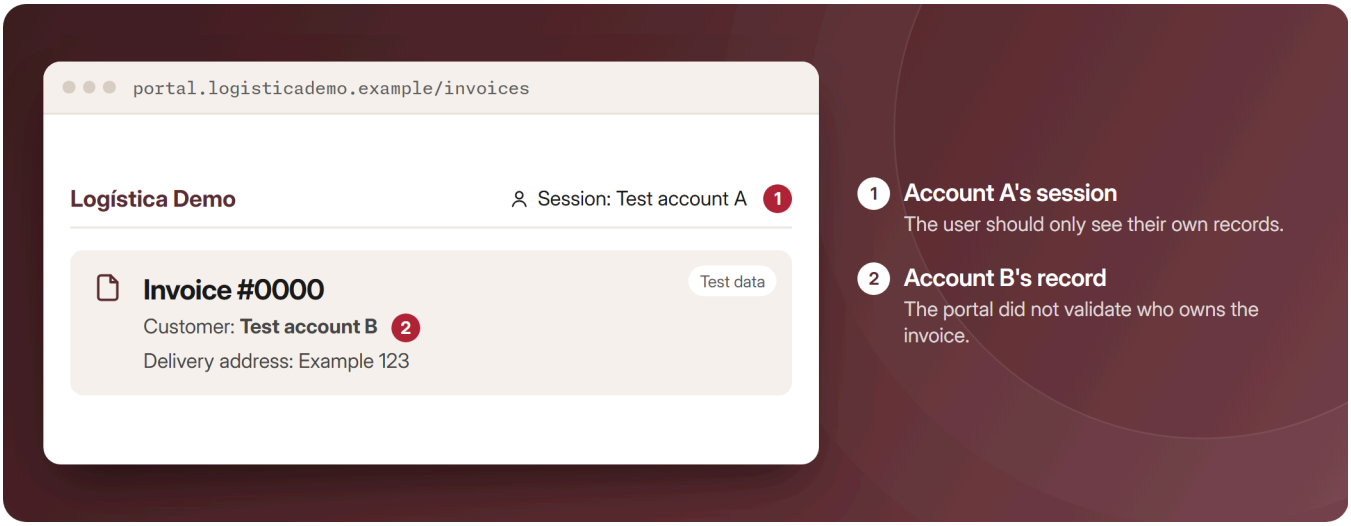
The portal checks that the user is logged in, but not that the requested record belongs to them. The test was run between two test accounts created for this purpose.

Business impact

A customer could view another's business information and change delivery addresses, creating contractual and operational risk.

Remediation recommendations

- Validate on the server, on every request, that the record belongs to the user.
- Use hard-to-predict identifiers as an additional measure.
- Add automated access control tests to the development cycle.



Evidence. Invoice of test account B visible from test account A's session. Illustrative image: the actual report includes the real tool screenshot.

Steps to reproduce

1. **Preparation**
   Two test accounts, A and B, were created with the client's authorization.
2. **Test record**
   A test invoice was generated in account B.
3. **Verification**
   From account A's session, the team confirmed that the portal displayed account B's invoice.
4. **Cleanup**
   The test accounts and data were deleted at the end.

General steps. Technical detail is omitted from this public sample.

REFERENCES OWASP WSTG-ATHZ-04 · CWE-639

SOC-01 · SOCIAL ENGINEERING

Credentials submitted during the controlled phishing campaign

RISK	CVSS 3.1	AFFECTED ASSET
High	Not applicable	120 employees included in the campaign

Risk defined by likelihood and impact

What we found

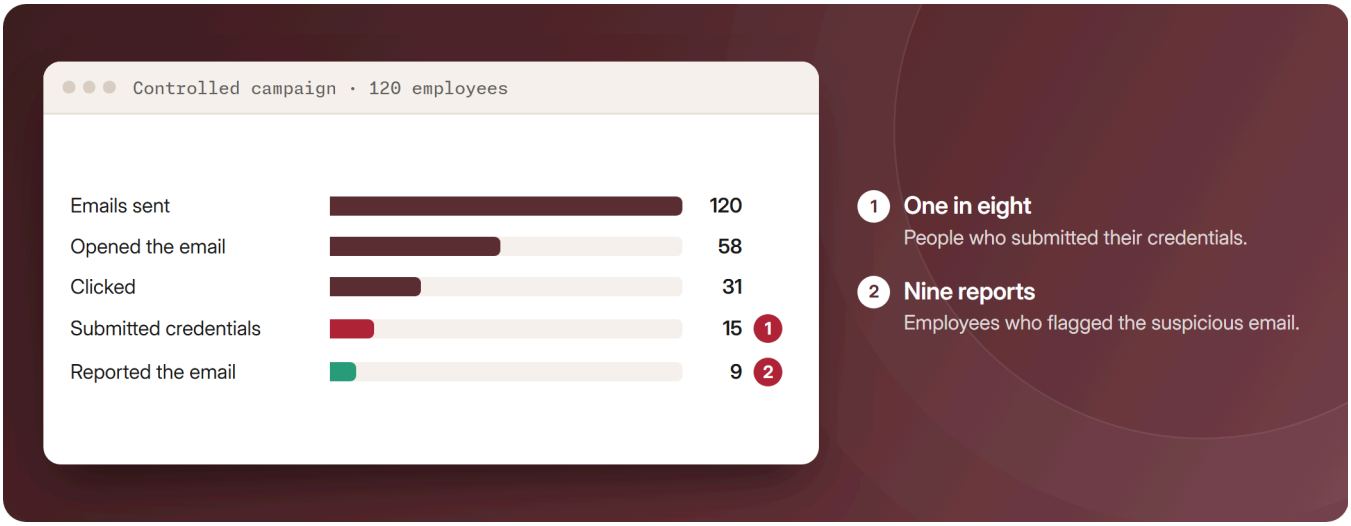
A controlled phishing campaign was sent to measure how prepared the team is. Results are presented in aggregate and do not identify any individual.

Business impact

One in eight people submitted their credentials. Combined with EXT-01, this was the entry point of the internal path.

Remediation recommendations

- Train with examples close to each area's daily work.
- Make it possible to report suspicious email with one click.
- Recognize those who report, without penalizing those who make a mistake.



Evidence. Aggregate results of the controlled phishing campaign. Illustrative image: the actual report includes the real tool screenshot.

Steps to reproduce

1. **Planning**
   The employee group, dates and campaign rules were agreed with the client.
2. **Execution**
   The campaign was sent over five business days, without storing any password.
3. **Measurement**
   Opens, clicks and reports were recorded in aggregate.
4. **Presentation**
   Results were delivered without identifying any individual.

General steps. Technical detail is omitted from this public sample.

REFERENCES MITRE ATT&CK T1566.002 · NIST SP 800-115

INT-04 · INTERNAL NETWORK & IDENTITIES

Legacy name resolution protocols enabled

RISK	CVSS 3.1	AFFECTED ASSET
Medium	6.5	Workstations on network 10.20.0.0/16

AV:A/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

What we found

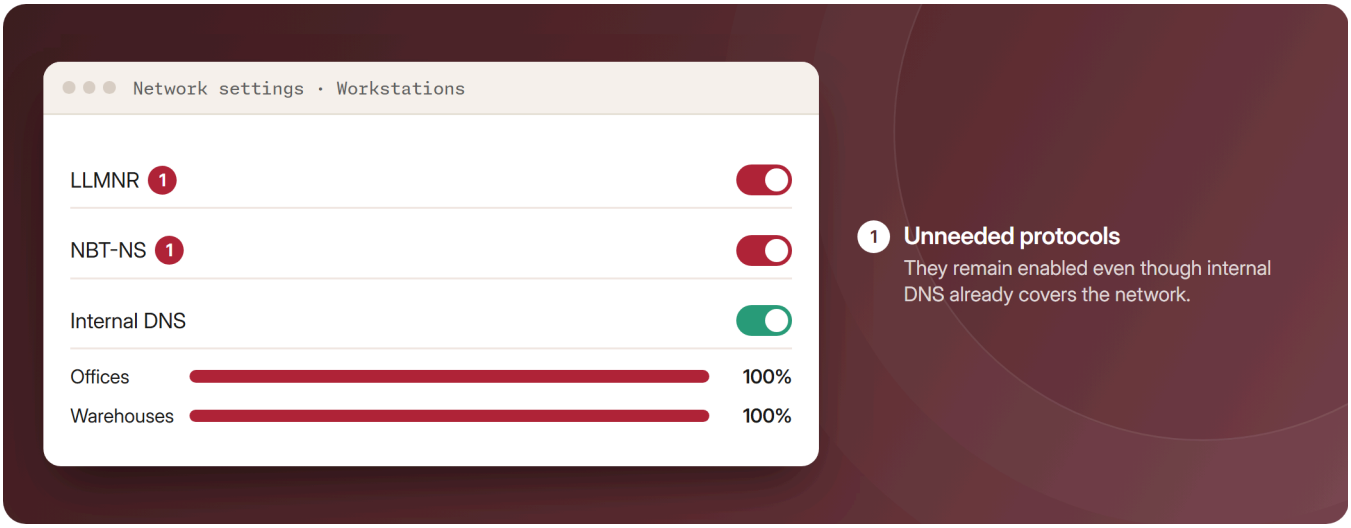
Machines keep LLMNR and NBT-NS enabled, older protocols that the network does not need and that trust any machine that responds.

Business impact

Someone connected to the internal network could obtain other users' authentication information.

Remediation recommendations

- Disable LLMNR and NBT-NS through group policy.
- First confirm that internal DNS covers all names in use.



Evidence. Status of name resolution protocols in the workstation sample. Illustrative image: the actual report includes the real tool screenshot.

Steps to reproduce

1. **Sample selection**
   Workstations were chosen from each network segment.
2. **Configuration review**
   The team reviewed which name resolution protocols are enabled.
3. **Confirmation**
   LLMNR and NBT-NS were enabled across the entire sample.
4. **DNS validation**
   The team confirmed that internal DNS covers the names in use, so these protocols are not needed.

General steps. Technical detail is omitted from this public sample.

REFERENCES MITRE ATT&CK T1557.001 · NIST SP 800-53 CM-7

OSI-01 · OSINT

Corporate information exposed in open sources

RISK	CVSS 3.1	AFFECTED ASSET
Medium	5.3	Public information about the company and its staff

AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

What we found

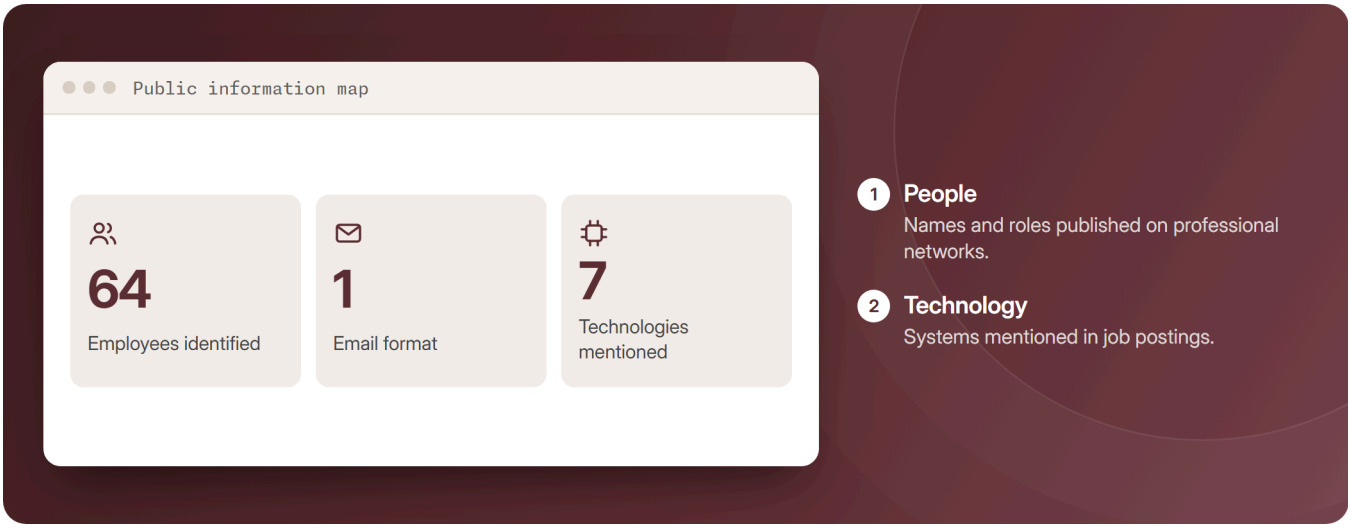
Public information revealed employee names and roles, their email format, and details of the technology the company uses, published in job postings.

Business impact

This information makes a deception more believable and helps an attacker plan their next steps.

Remediation recommendations

- Define what technical information can be published, for example in job postings.
- Guide staff on what they share on professional networks.
- Repeat this review regularly.



Evidence. Summary of the public information found about the company. Illustrative image: the actual report includes the real tool screenshot.

Steps to reproduce

1. **Source review**
   The company website, professional networks and public job postings were consulted.
2. **Classification**
   The information was organized by people, email and technology.
3. **Assessment**
   The team assessed how an attacker could use each type of information.
4. **Recording**
   Only what was necessary was documented, leaving out unnecessary personal data.

General steps. Technical detail is omitted from this public sample.

REFERENCES MITRE ATT&CK T1589 · T1593

EXT-02 · EXTERNAL PENTESTING

Email domain without a DMARC reject policy

RISK	CVSS 3.1	AFFECTED ASSET
Medium	4.3	logisticademo.example

AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:L/A:N

What we found

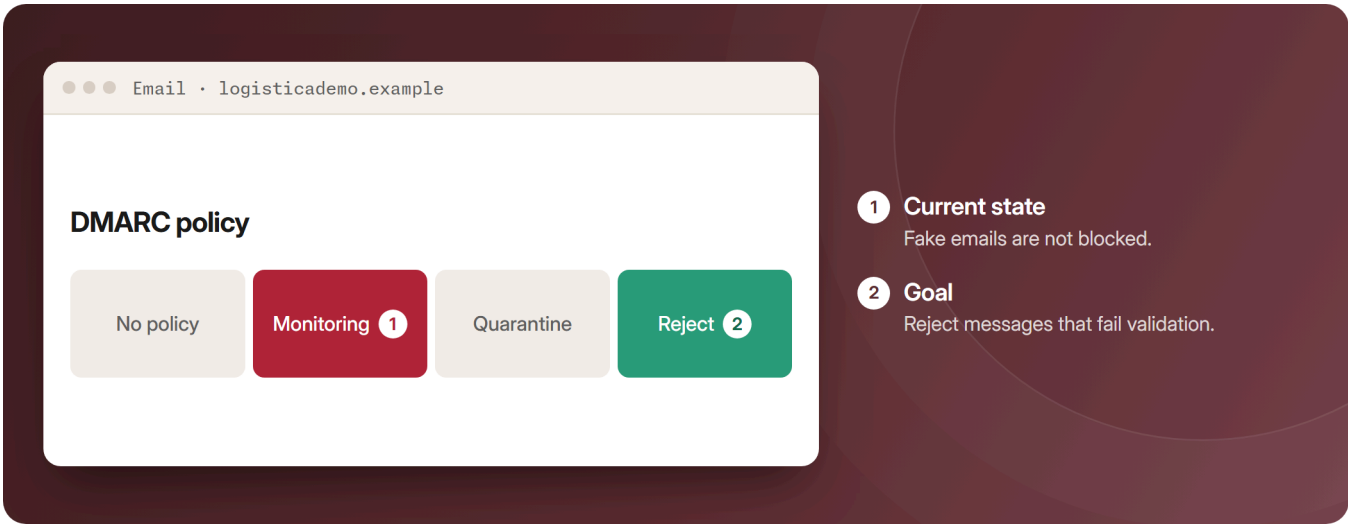
The domain does not tell mail servers what to do with messages that appear to come from the company but do not. Its DMARC policy is in monitoring mode only.

Business impact

It makes it easier for someone to send fake email in the company's name to customers or employees.

Remediation recommendations

- Review which systems send email on behalf of the domain.
- Gradually move toward a DMARC reject policy.



Evidence. Current DMARC policy level for the domain and recommended level. Illustrative image: the actual report includes the real tool screenshot.

Steps to reproduce

1. **Record lookup**
   The domain's public email records were consulted.
2. **Policy review**
   The team confirmed that the DMARC policy is in monitoring mode.
3. **Comparison**
   The configuration was compared with recommended practice for corporate domains.
4. **Improvement path**
   A gradual move toward a reject policy was defined.

General steps. Technical detail is omitted from this public sample.

REFERENCES RFC 7489 · MITRE ATT&CK T1566

EXT-03 · EXTERNAL PENTESTING

Obsolete encryption protocols on the mail server

RISK	CVSS 3.1	AFFECTED ASSET
Low	3.1	correo.logisticademo.example

AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N

What we found

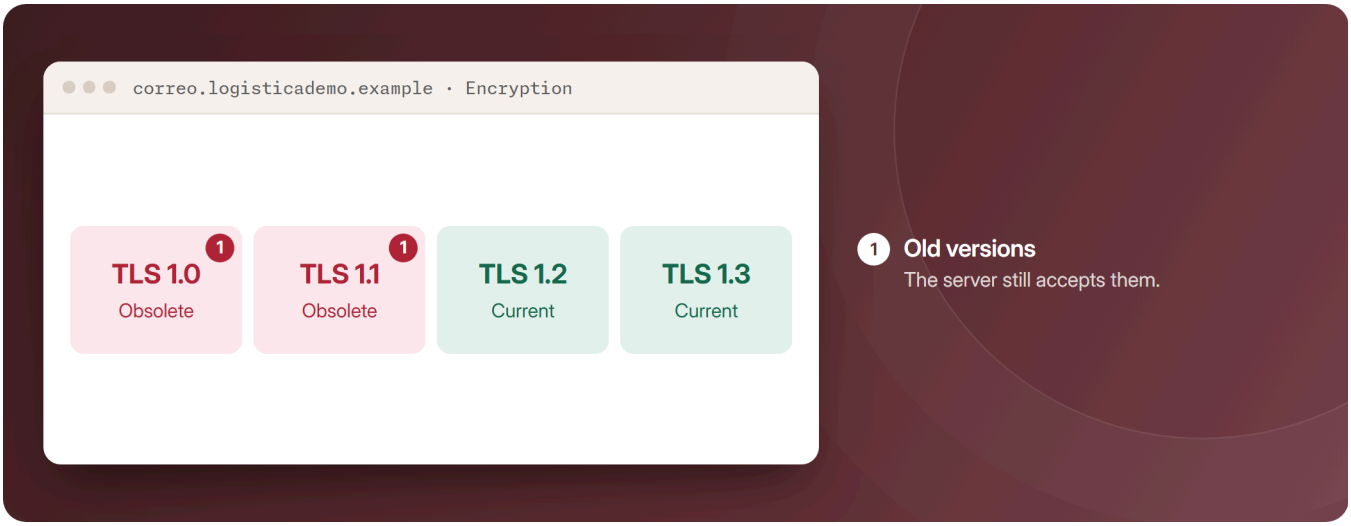
The mail server still accepts TLS 1.0 and 1.1, versions that are no longer considered secure.

Business impact

The immediate risk is low, but these versions weaken the protection of communications.

Remediation recommendations

- Disable TLS 1.0 and 1.1, and keep TLS 1.2 or later.



Evidence. Encryption versions accepted by the mail server. Illustrative image: the actual report includes the real tool screenshot.

Steps to reproduce

1. **Server check**
   The encryption versions accepted by the mail server were checked.
2. **Comparison**
   The result was compared with current versions, according to RFC 8996.
3. **Confirmation**
   The team confirmed that TLS 1.0 and TLS 1.1 are still accepted.
4. **Recording**
   The obsolete versions were documented so they can be disabled.

General steps. Technical detail is omitted from this public sample.

REFERENCES RFC 8996 · CWE-327

CONCLUSION

Conclusion

The assessment identified 13 findings, of which 2 are critical and 7 are high.

Both demonstrated paths depend on a small number of weaknesses. Fixing WEB-01, INT-01 and EXT-01 closes both paths and significantly reduces the overall risk of Logística Demo, S.A. The remaining findings should be addressed according to the prioritized remediation plan.

Testing closure

Test items	Removed from the systems tested.
Test accounts	Deleted when portal testing ended.
Operations	No disruptions were recorded during testing.
Customer data	No customer data was extracted.

tekras

© 2026 Tekras. All rights reserved.